

Privacy Policy

Open-Source Software Privacy Policy

Last Updated: 5 July 2026

1. Introduction

UMANITEK AG (“Umanitek,” “we,” “us,” “our”) publishes **Umanitek Agent Blackbox** (the “Software”), free, open-source security software that runs inside an AI agent. This Privacy Policy explains how data is handled when you use the Software. Because the Software is self-hosted and runs locally on your own machine, there is no user account or login, and Umanitek does not operate a central server that collects your usage data.

UMANITEK AG

Untermüli 7, 6300 Zug, Switzerland

Company Registration Number: CHE-171.163.797

Contact: support@umanitek.ai · umanitek.ai

Key point: Most of what the Software does stays entirely on your device. A small number of features intentionally send limited data off your machine - primarily to a public, decentralized threat graph. This policy describes exactly what those are so you can make an informed choice. By using the Software you acknowledge that you have read and understood this Privacy Policy; if you do not agree, do not use the Software.

This policy covers the open-source Software only. The separate hosted Umanitek Agent Blackbox service and the umanitek.ai website are covered by their own privacy notices.

2. Who Is the Controller

For data you generate and store locally, **you** are the controller of your own installation. UMANITEK AG acts as controller only with respect to the curated public threat graph it maintains and any correspondence you send us. Where the Software writes to the decentralized OriginTrail DKG, that data is published to a distributed, community-operated network rather than to Umanitek’s private servers (see Section 4).

3. Data That Stays on Your Machine

By default, the following is created and stored **locally only**, under the Software’s home directory, and is not transmitted to Umanitek:

- **The content of your agent’s actions** - the actual prompts, shell commands, file paths, and package details the Software inspects. Observed prompt and command text never leaves your machine as part of a threat report; it stays in your node’s private local audit records.
- **Local audit and findings logs** (e.g., `audit.jsonl`, `findings.jsonl`), which are redacted and size-bounded.
- **Your protected paths** - files and folders you designate (such as `~/.ssh/*` or `**/*.env`). These always block locally and are never transmitted anywhere.

- **Your configuration** - settings such as detection categories, severity thresholds, and audit/block mode.
- **AI reviewer verdicts** - if you enable the optional AI reviewer, its verdicts stay on your machine and are never shared to the community graph.

4. Data Sent to the Shared Threat Graph (Community Reporting)

The Software's core value is shared threat intelligence: when it identifies a likely threat, it can report a compact identifier to a **community threat graph on the OriginTrail Decentralized Knowledge Graph (DKG)**, so other agents are protected. Reporting is subject to configurable rate limits, minimum-severity thresholds, and per-identifier cooldowns, and can be disabled entirely.

What a report contains:

- A **deterministic threat identifier** - e.g. a dependency identifier such as "dep:npm:evil-package@1.0.0", a **hash** of a prompt-injection pattern (not the raw text), or an escalation identifier describing a tool and argument shape;
- A **severity level** and threat category;
- A **pseudonymous submitter identifier** - a lowercased blockchain address associated with your node, used to make reports first-writer-safe and to build consensus.

What a report does NOT contain: the observed prompt or command text, your file contents, your IP address, your name, or other directly identifying personal data. That privacy-sensitive evidence remains in your local, private records.

Characteristics of the DKG you should understand:

- **Public.** The community and public threat graphs are readable by anyone.
- **Persistent and tamper-resistant.** Data written to a decentralized ledger is designed to be permanent and cannot be quietly altered or fully deleted. Treat anything reported as potentially permanent and public.
- **Pseudonymous, not anonymous.** A persistent node/blockchain address can, in principle, be correlated across reports. Do not use reporting in a way that would tie sensitive activity to an identity you wish to keep private.

Your control: You can reduce or disable reporting via configuration (report toggle, daily report limits, and minimum severity). If you never want to contribute to the community graph, disable reporting.

5. Reading the Public and Community Graphs

To protect your agent, the Software syncs threat rulesets from the DKG via a local or configured DKG node. Reading the public curated graph is a normal network operation. Depending on your node configuration, network intermediaries may observe that your node is syncing, as with any other network request.

6. Optional Vulnerability Lookups (OSV and similar)

If enabled, the Software may query public vulnerability databases (such as the Open Source Vulnerabilities - OSV - service) to check dependencies. Such a query may transmit package names and

versions to that third-party service, governed by the third party's own privacy practices. You can disable this in configuration.

7. Optional AI Reviewer (Third-Party Model Providers)

The Software includes an **optional, off-by-default** AI reviewer that can send a suspected prompt-injection sample to a third-party model provider (such as OpenAI or Anthropic) for a second opinion. If you enable it:

- The text being reviewed is transmitted to the provider you choose, using an API key you supply;
- That transmission is subject to the provider's privacy policy and data-handling terms, not Umanitek's;
- The reviewer only flags - it never blocks - and its verdicts remain on your machine and are never shared to the community graph.

If you do not want any content sent to third-party model providers, leave the AI reviewer disabled (it is off by default).

8. What Umanitek Does and Does Not Collect

Umanitek does not: require an account, run analytics or telemetry that phone home from your installation, collect your IP address, or receive your prompts, commands, or file contents.

Umanitek may: maintain and curate the public threat graph (including reviewing community reports to promote genuine threats), and respond to correspondence you send to support@umanitek.ai. We never sell, rent, or trade personal data.

Data retention. Because most data never reaches Umanitek, retention is primarily a matter of your own configuration and local storage. For correspondence you send to support@umanitek.ai and for the curated public graph, Umanitek retains data only for as long as reasonably necessary for the purposes described in this Policy, to comply with legal obligations, resolve disputes, and enforce our agreements, and in any event no longer than thirty-six (36) months from your last contact, unless a longer period is required by law or necessary to maintain the integrity of the curated threat graph.

8A. Security Incident Notification

If Umanitek becomes aware of a security incident affecting personal data that Umanitek controls (primarily correspondence and the curated public-graph infrastructure), it will notify affected individuals and, where required, competent supervisory authorities without undue delay and in accordance with applicable law, including the GDPR and the Swiss FADP. Because the decentralized DKG is operated by independent node operators outside Umanitek's control, Umanitek cannot guarantee detection of, or provide notification for, incidents occurring on infrastructure it does not operate.

9. Legal Bases (EU/EEA/UK/Swiss Users - GDPR & FADP)

Where the GDPR or the Swiss FADP applies, our limited processing relies on:

- **Consent** (GDPR Art. 6(1)(a)) - for optional features you switch on, such as community reporting, OSV lookups, and the AI reviewer. You may withdraw consent at any time by disabling the feature; withdrawal does not affect processing carried out before withdrawal.
- **Legitimate interests** (GDPR Art. 6(1)(f)) - for operating and improving shared threat intelligence and protecting users' systems, balanced against your rights. Threat identifiers are designed to minimize personal data.
- **Legal obligation** (GDPR Art. 6(1)(c)) - where we must process data to comply with law.
- **Contract** (GDPR Art. 6(1)(b)) - for correspondence and support requests you initiate, where processing is necessary to respond to your request.

Data minimization / privacy by design: the Software reports identifiers and hashes rather than raw content.

9A. Sub-processors and Service Providers

Umanitek may engage third-party service providers (for example, email and IT-infrastructure providers) to help operate correspondence and the curated public graph. Any such provider is bound by contractual confidentiality and data-protection obligations consistent with this Policy and may only process personal data on Umanitek's documented instructions.

10. Your Privacy Rights

Depending on your location and subject to applicable law, you may have rights to access, rectify, erase, restrict, or object to processing of your personal data, to data portability, to withdraw consent, and to lodge a complaint with a competent data-protection authority. Because most data stays on your own device, you can exercise many of these rights directly - for example, by deleting local logs or changing your configuration.

Important limitation - the decentralized graph: data published to the DKG is by design permanent and distributed across a network Umanitek does not control. As a result, erasure or rectification of already-published reports may be technically impossible. This is an inherent property of the technology, which is why the Software minimizes what is reported and why reporting is configurable. Please consider this before enabling reporting.

United States. Depending on your state (for example under the California Consumer Privacy Act/CPRA and similar laws), you may have rights to know, delete, correct, and opt out of the "sale" or "sharing" of personal information. Umanitek does not sell personal information. The same technical limitation regarding already-published decentralized data applies.

To exercise rights with respect to data Umanitek actually controls (primarily the curated public graph and correspondence), contact us at support@umanitek.ai with "Privacy Rights Request" in the subject line. We will respond within 30 days or as required by applicable law.

Limitation. To the maximum extent permitted by applicable law, any liability of Umanitek arising out of or relating to this Privacy Policy is subject to the limitations of liability set out in Section 8 of the Terms of Service, which forms part of the agreement between you and Umanitek.

11. International Data Transfers

The DKG and any third-party services you enable operate globally, so data you choose to transmit may be processed in countries outside your own, including outside Switzerland and the EEA. Where Umanitek transfers personal data internationally, it relies on appropriate safeguards (such as Standard Contractual Clauses) where required. For the decentralized graph, data is inherently replicated across nodes in multiple jurisdictions.

12. Data Security

The Software stores its local data with the file-system permissions of your environment; you are responsible for securing the machine on which you run it, including access controls and your protected-paths configuration. For data Umanitek controls, we implement appropriate technical and organizational measures. No security system is perfect, and we cannot guarantee absolute security.

12A. Automated Processing; No Solely Automated Decisions with Legal Effect

The Software's detection logic and the optional AI reviewer perform automated flagging based on local rules, hashes, and, if enabled, third-party model output. These processes run locally, are configurable by you, and do not produce legal effects or similarly significant decisions concerning you within the meaning of GDPR Article 22; the Software only flags or, if you enable block mode, blocks actions on your own machine under your own configuration, and does not make decisions about you as a data subject.

13. Children

The Software is directed to developers and technically capable users and is not intended for anyone under 16. It does not knowingly collect personal data from children.

If Umanitek becomes aware that a minor's personal data has been included in a report submitted to the community threat graph, it will use commercially reasonable efforts to have the corresponding entry reviewed and, where feasible, addressed through its curation process; however, because of the persistent and tamper-resistant nature of the DKG described in Section 4, Umanitek cannot guarantee removal of previously published entries from the underlying decentralized ledger.

14. Changes to This Policy

We may update this Privacy Policy as the Software evolves. The “Last Updated” date above shows the current version, and material changes will be reflected in the project repository. Prior versions of the open-source Software remain available under the terms under which they were released.

15. Contact

UMANITEK AG

Untermüli 7, 6300 Zug, Switzerland

Company Registration Number: CHE-171.163.797

Contact: support@umanitek.ai · umanitek.ai